dinosn/cve-2026-103849-blockstrap-lab: VALIDATION.md

dinosn/cve-2026-103849-blockstrap-lab: VALIDATION.md - Author not stated, GitHub.

- Published: date not stated
- Original: <https://github.com/dinosn/cve-2026-103849-blockstrap-lab/blob/e9ce56baa725bcfdd28570156c0cff1a4203a1e6/VALIDATION.md>
- Preserved from: https://github.com/dinosn/cve-2026-103849-blockstrap-lab/blob/e9ce56baa725bcfdd28570156c0cff1a4203a1e6/VALIDATION.md (github-api) on 2026-10-21
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Web Hacking Techniques Index collections, kept so it remains readable if the page goes offline. To read the original, follow the link above.

Content

> UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

> **Repository reading copy.** Created from VALIDATION.md.

VALIDATION.md

`dinosn/cve-2026-103849-blockstrap-lab` at `e9ce56baa725`, path `VALIDATION.md`.

Validation record

Verdict

Passed for the BlockStrap primitive, an unauthenticated HTTP carrier, and — with an explicitly installed lab-only gadget — a conditional remote command-execution chain. On 2026-10-18, the lab reproduced attacker-controlled stock-block execution from an unauthenticated guest GraphQL flow on Magento Open Source 2.4.9 with the September VULN-39341 hotfix applied. Applying the October APSB26-153 engine fix stopped the same directive while preserving the surrounding failed-payment email flow.

The stock full-RCE proof gap remains open. The optional command test installs a minimal module authored for this lab to model the additional gadget precondition that a real extension or deployment would have to satisfy. It executes only the fixed command `id` as `www-data`, accepts a strict random nonce for correlation, makes no callback, and removes

its marker and module afterwards. No compatible stock gadget was identified in the bounded search described below, but that search does not prove absence.

Target and isolation

Item	Recorded value
Authorized Docker host	private lab host, redacted in public copy
Compose project	`cve-2026-103849-lab`
Magento source	Magento Open Source 2.4.9
Source commit	`755e34dd689021c5165db9d35ecff74f7dc51527`
Host architecture	`amd64`
Docker / Compose	`20.10.25+dfsg1` / `2.26.1-4`
Magento gateway	`127.0.0.1:18096` only
MailHog API/UI	`127.0.0.1:18097` only
Dedicated bridge	`10.210.103.0/24`
Final source/application state	patched; lab gadget removed

The database, Redis, OpenSearch, PHP-FPM, and SMTP ports remain internal to the dedicated Compose network. No unrelated Docker project or network was changed.

Trigger and impact prerequisites

The reproduced unauthenticated carrier requires all of the following:

- an affected template engine state with VULN-39341 applied and the later

APSB26-153 BlockStrap fix absent;

- `Magento_PaypalGraphQl` enabled and `/graphql` reachable;
- guest checkout allowed for the generated cart;
- a visible `company` address attribute and the default HTML address format,

or an equivalent recursively filtered format that preserves the carrier;

- the failed-payment template still rendering `billingAddressHtml`, with

valid template, recipient, and transport configuration so rendering occurs.

The MailHog message is a lab oracle. A remote production attacker normally cannot read the merchant failure email, so the stock Text result is proof of dispatch rather than an attacker-visible output channel. Command execution additionally requires a compatible `BlockInterface` gadget in the deployed code and any runtime features that gadget depends on. This lab supplies that extra condition explicitly.

The quote-address `company` column is limited to 255 characters. The hardened conditional gadget carrier is 208 ASCII bytes. This exact route therefore does not establish that an arbitrary longer real-world gadget class and parameter set would fit.

Pinned patch evidence

Artifact	SHA-256
`VULN-39341_249-monorepo.patch`	`d255853dd45cadef9a8d5116617fd4531657c25e11d4895b0691b7ea54e1e27f`
`APSB26-153_BlockStrap_249-monorepo.patch`	`d5eee900bef4b9fc072c6c18fbff2f2c2d5b8128e7fe0b973da85a0742171575`

The source member `249-2026-10-001-CE.patch` has SHA-256 `9cecb600c0fbb71ac3e52e10926ef4f0f5b8cd770d0c502cd8dce4f5642eff81`. It is available in Adobe's official archive and is not redistributed here; NOTICE.md records the complete provenance chain.

`scripts/set-state.sh` requires VULN-39341 in both states and refuses an unknown source state. The four-file October template-engine change is the only intentional code-state difference; each side uses a fresh cart and nonce.

Component A/B

The component harness used the real Magento object manager and shared filter services. Its success value was `CUSTOM_BLOCK_<fresh nonce>`, generated by the stock `Text::getCacheKey()` method and absent from the input.

Observation	VULN-39341 only	October fixed
Controls passed	yes	yes
Exact child filter used	yes	yes
Child ran at depth 1	yes	yes
Child output was textually signature-wrapped	yes	no
Smuggled block executed	yes	no
Original directive remained inert	no	yes
Expected probe exit	`0`	`2`

The wrapper reported:

```
[PASS] The BlockStrap directive-injection primitive matches both A/B controls.
```

Full output: component A/B evidence.

Unauthenticated HTTP/email A/B

Each run independently created a guest cart, stored the recursive billing address carrier, and submitted a declined Payflow response through the public GraphQL mutation. MailHog was cleared before each run. Both states captured exactly one message containing that run's fresh nonce, so unrelated or missing mail could not satisfy the patched oracle.

Observation	VULN-39341 only	October fixed
Guest setup completed	yes	yes
Trigger HTTP status	`200`	`200`
Expected GraphQL decline error	yes	yes
Failed-payment email captured	yes, one	yes, one
Transformed marker absent from request	yes	yes
`CUSTOM_BLOCK_<nonce>` observed in email	**yes**	**no**
State expectation matched	yes	yes

The vulnerable marker SHA-256 was `781422f166ab4b172d457c896573ec39468e3414625d3e844d0f8eec58d263ca`; the captured vulnerable MailHog snapshot SHA-256 was `8819aecba77f37050582164af93871d63ef4226ae6352799ac8bf8625d756f69`. The wrapper reported:

```
[PASS] The unauthenticated HTTP/email BlockStrap primitive matches both A/B controls.
```

Full output is included in the combined revalidation evidence.

Bounded server-side file-creation A/B

The final probe selected the stock `Magento\Backend\Block\Widget\Grid\Extended::getCsvFile()` method. A host-side oracle snapshotted the fixed `var/export` directory before and after each equivalently constructed HTTP trigger.

Observation	VULN-39341 only	October fixed
HTTP trigger completed	yes	yes
New `var/export` CSV files	**one**	**zero**

Observation	VULN-39341 only	October fixed
New filename matched `[0-9a-f]{32}.csv`	yes	n/a
New file size	4 bytes	n/a
New file bytes	`EF BB BF 0A`	n/a
New file SHA-256	`b42f2099187886def637d6aa840022266e05cb6c987a9394e708e23cd505eb46`	n/a
Failed-payment email captured	no; block failed after the write	yes

The wrapper reported:

```
[PASS] The fixed-directory, random-name file-creation oracle matches both A/B controls.
```

The wrapper then removed only the newly observed 32-hex CSV and restored the patched source. Fresh output is included in the combined revalidation evidence.

This is a bounded persistent side effect: the path is a fixed Magento export directory, the filename is generated by Magento, and the four bytes are fixed. It is not an arbitrary file write.

An earlier candidate, `Magento\Backend\Block\Widget\Grid\Export`, was rejected because its layout hook dereferenced a missing parent before its requested file method could run. The vulnerable request created zero files through that class.

Conditional command-execution A/B (lab-only gadget)

Passed on 2026-10-18. The unauthenticated HTTP carrier reaches operating system command execution after the lab installs `BlockStrapLab_Gadget` (`gadget/BlockStrapLab_Gadget/Block/Rce.php`). The module is synthetic: it is not a Magento stock class, a known extension gadget, or one of the withheld Sansec chains. It runs only fixed `id`; the directive controls a strict nonce. The carrier, recursive filter transition, later email-filter `blockDirective()` dispatch, and zero-argument `output=` selection are stock. The gadget is present in both A/B states, so the October engine patch is the only intentional code-state difference.

Observation	VULN-39341 only	October fixed
Guest setup + carrier stored	yes	yes
Trigger HTTP status	`200`	`200`
Failed-payment email captured	yes, one	yes, one
Nonce-correlated `RCEGADGET` value in email	**yes**	**no**

Observation	VULN-39341 only	October fixed
Decoded command output	`uid=33(www-data) gid=33(www-data) groups=33(www-data)`	none
Nonce marker file in `var/export`	**yes**, contains `id` output	**none**
State expectation matched	yes	yes

The wrapper removed the observed marker file and gadget module, then restored and verified the patched source. Full output: RCE A/B evidence (sha-256 `5a2fbe25bb71b74115b989ee36aeecc97dc76565433f6320de7ae08de12ba8f6`). An independent post-run check confirmed healthy containers, loopback-only published ports, the October patch applied, the gadget absent and disabled, and zero residual nonce marker files. Full output: post-run state evidence (sha-256 `c94ef6a91424c8ccea39df7786e16b18dc28321ccee982596d636b429d05dab3`).

Reproduce: `make http-rce-ab`.

Bounded gadget search (why the lab-only module exists)

The RCE step reported by the original researchers was not reproduced with stock classes on this exact tree. This is a bounded negative result:

1. **Static sink review.** Two working sweeps reviewed

BlockInterface-implementing classes plus the framework view layer for include/require-variable, eval-family, process-family, `call_user_func` with attacker-influenced callable, `new $var`, variable-class `objectManager->create`, and unserialize sinks reachable from a public zero-argument block method or `toHtml` with flat-string data params. Their complete raw results were not retained in this package, so they are search notes rather than proof of absence.

1. **Deepest stock gadget.**

`Magento\GoogleOptimizer\Block\Adminhtml\Form::_prepareForm()` passes the `code-entity` data param to `objectManager->create()` with no inner BlockInterface check — class instantiation plus a `getCode()` call. The exploratory dynamic run did not observe a command or attacker-influenced write through that shape.

1. **Dynamic instantiation sweep.** A private exploratory run reported 15,917

enumerated classes, 12,119 successful constructions, and 332 `getCode()` calls. It excluded the Sales namespaces and some constructor shapes, invoked only `getCode()`, and used a filesystem-diff oracle that cannot detect process-only or network-only effects. The broad sweep tool and raw output are not packaged. The counts therefore describe tested coverage; they cannot establish that no gadget exists.

1. **Array-shape constraint.** The ITW StyleSmuggler DI chain

(ColumnSet → UrlGeneratorFactory → `parseArray` instance gadgets) needs an attacker-keyed array as a directive param value. VULN-39341 closed the array source (admin-gated preview, string-forced `setTemplateStyles`), and the failed-payment template variables contain no attacker-keyed arrays, so the chain is doubly unreachable here.

The lab module demonstrates the separate condition “a compatible extension gadget is installed.” The result does not generalize to Adobe Commerce proprietary modules, other affected versions, third-party extensions, or different deployment configuration. Stock full RCE remains unproven.

Reproduction

```
make verify
make ab
make http-ab
make file-ab
make http-rce-ab
```

A fresh combined regression of all four tracks passed on the authorized host. Its transcript is full revalidation evidence (sha-256 `a9339304a40490df45ac1a1795d355e1e463116d6dc9c2119e7dc21e31af059c`).

All A/B wrappers verify restoration of the October-patched source in an exit trap and fail if cleanup cannot be confirmed. The file wrapper also removes matching CSVs created since its initial snapshot. `run-rce-ab.sh` verifies that marker files are absent and the synthetic gadget is disabled and removed. Recorded environment, bindings, source revision, and hashes are in the environment evidence; static checks are in the verification evidence, and the validated container image IDs are in Docker image evidence.

Superseded private runs, including the former operator-command gadget and pre-correlation transcripts, are intentionally omitted from the public tree. They are not the evidence basis for the verdict above.

Archived from https://github.com/dinosn/cve-2026-103849-blockstrap-lab/blob/e9ce56baa725bcfdd28570156c0cff1a4203a1e6/VALIDATION.md. Rendered offline from the local Markdown copy.